scientific reports

Check for updates

OPEN

Phishing URL detection with neural networks: an empirical study

Hayk Ghalechyan[1,2], Elina Israyelyan[1,2], Avag Arakelyan[1], Gerasim Hovhannisyan[1] & Arman Davtyan[1]✉

Cybercriminals create phishing websites that mimic legitimate websites to get sensitive information from companies, individuals, or governments. Therefore, using state-of-the-art artificial intelligence and machine learning technologies to correctly classify phishing and legitimate URLs is imperative. We report the results of applying deterministic and probabilistic neural network models to URL classification. Key achievements of this work are: (1) The development of a unique approach based on probabilistic neural networks that improves classification accuracy. (2) We show for the first time in URL phishing research that a machine learning model trained on a combination of open source and private datasets is successful in production. The dataset is constructed from open sources like Alexa, PhishTank, or OpenPhish and, most importantly, real-world production data from EasyDMARC. The daily validation of the model using daily reported URL data and corresponding labels, both from open-source platforms and private production, reach on average a 97% accuracy on the validation dataset, labeled by PhishTank, OpenPhish and EasdDMARC where possible mislabeled data can not be excluded and was not possible to check due to large number of URLs. Feature engineering was done without third-party dependencies. Lastly, the evaluation of both deterministic and probabilistic models shows high accuracy on short and long URLs, where short URLs are defined as having less than 50 characters.

Keywords Phishing URL, Neural network, Probabilistic neural networks, Uncertainty, Empirical data

Phishing attacks continue to grow in volume across industries, the most targeted of which include financial institutions, Software-as-a-Service (SaaS) and webmail services, social media platforms, payment services, eCommerce and retail. In the 1st quarter of 2022, a historical maximum of 1,025,968 phishing attacks was reported[1] by the Anti-Phishing Working Group (APWG). A significant cause for concern is phishing Uniform Resource Locators (URLs), the amount of which dominates in the phishing attacks observed by APWG. In March 2022 alone, APWG observed 384,291 unique phishing websites, which is around eight times more than the number reported in March 2012[2].

The volume of phishing websites is expected to grow further and reach victims not only via email but also through SMS, WhatsApp, Viber, Signal, and other communication channels as well as social networks widely used nowadays (Facebook, X/Twitter, etcetera). A recent study by Interisle Consulting Group[3] showed a 61% increase in phishing attacks over the period of May 2020 to April 2021, with a 72% increase in reported phishing domain names. The study also reported 588,321 new domain names registered by phishers, an 83% increase over the same period. At the same time, it's becoming harder to detect phishing websites. One reason for this is the significant increase in recent years of phishing websites using Hypertext Transfer Protocol Secure (HTTPS) encryption[4], an indicator that users typically associate with legitimate and secure websites. Carrol et al.[5] highlight the difficulty study participants had detecting modern phishing email attacks, reinforcing that as a society, we need to push for a digital existence that enables users to effectively detect threats like the phishing attack and then to be able to trust and distrust accordingly. We need to harness the technology to support the end users while they exist online.

Phishers typically create fraudulent, realistic-looking websites with unsuspicious URLs to deceive victims into divulging login credentials and sensitive information like social security numbers, credit card details, etcetera. Their usual tactics are as follows: the bad actor sends the legitimate-looking phishing link to the victim via email, a social network platform, instant message, or other forms of electronic communication, posing as a reputable entity or individual.

When the target follows the URL, they are directed to the fake login page, where they enter their login details, as they would on the genuine login page. The phisher then obtains the unknowing victim's credentials and access to their user account and private information to commit identity theft, data theft, and/or financial theft.

[1]EasyDMARC, Data Science, 0014 Yerevan, Armenia. [2]These authors contributed equally: Hayk Ghalechyan and Elina Israyelyan. ✉email: armand@easydmarc.us

The goal of the phishing attack is not only to steal and exploit the victim's identity and data, but it can also be executed to plant malware on the target's device or conduct further cybercrimes. Business Email Compromise (BEC) and ransomware are two prolific attack types that often have devastating financial consequences for organisations.

Indeed, phishing was identified as the leading initial access vector in the cybercrime incidents observed in the IBM Security X-Force Threat Intelligence Index 2022 Report[6]. With the advent of readily available and easy-to-use phishing kits like TodayZoo[7], even threat actors with minimal resources and expertise can acquire access to a victim's device, browser, online banking account, credit card details, web service profiles, platform-specific user accounts and company or home networks.

As the world becomes increasingly connected, the attack surface continues to expand. Such cyberattacks are only evolving, further escalating the threat of phishing. By 2025, it is estimated that over 27 billion Internet of Things (IoT)[8] devices will exist, encompassing internet-connected hardware devices such as home and network appliances, sensors, wearables, vehicles, and machinery. Despite IoT devices' rapid and innovative application, this technology has significant security risks. In fact, 98% of all IoT device traffic is unencrypted, and bad actors most frequently breach the first line of defence via phishing attacks. Moreover, IoT-enabled devices have bypassed the consumer market and emerged in industrial, agricultural, and energy fields, bringing forth a new source of risk[9,10]. Indeed, inadequately secured IoT devices used in critical infrastructure networks can increase the risk of operational assets and network breaches. Bad actors can use phishing to access IoT devices and commercial IoT-enabled systems. Such attacks could have devastating consequences depending on the scale and industry.

Conventional methods used to identify phishing websites are Blacklisting[11] and Whitelisting[12]. The detection mechanism is straightforward: one can check whether the URL is present in a confirmed URL Blacklist or Whitelist. However, most attackers are just as well-versed in Blacklists and Whitelists as cybersecurity specialists and can modify phishing URLs to take advantage of such open-source information. Changing the top-level domain or using insertion techniques to add repeated top-level domains are just a few techniques used to conceal malicious intent.

In these cases, it is possible to modify blacklisting techniques to take into account the heuristics of the URL[13]. In addition, it is important to understand how long such websites leave on average. In a recent study researchers from RWTH Aachen University studied 133,667 phishing websites and found that on average the phishing campaign lasts for 12 days[14].

Alternatives to conventional phishing website detection include inspection of source code[15], URL features[16], a combination of URL and HTML[17] or information extracted by third-party sources such as Whois[18], PageRank[19] and others. However, for any real-world business model, it is preferable to exclude third-party dependencies. Moreover, certain third-party dependencies have limitations. For example, the Whois module does not support Armenian websites with .am top-level domains, so no valuable Whois feature is available.

Nowadays, conventional phishing website detection methods and employee phishing education[20] are essential to reduce the success rate of phishing attacks[21]. However, they can not entirely eliminate the risk. Thus, it is imperative to take advantage of advanced Machine Learning (ML) algorithms to create an additional 24/7 monitoring and warning system for use in any organisation. ML has become a prominent focus of both academia and industry with massive potential in cybersecurity applications[22–29].

The assumption that humans can often differentiate the vast majority of phishing websites leads to the idea that such phishing websites share discerning features different from those of legitimate websites. Therefore, a sufficient number of features and/or careful feature engineering will enable ML algorithms to identify phishing websites. Several existing reports on phishing website detection methods using ML take advantage of different features and ML algorithms[30–36]. Despite all efforts and solid presentations of ML advantages from many researchers, there is a lack of reports on phishing website identification in real-world production datasets.

Our work reports that URL only based feature extraction together with Neural Network (NN) based ML model leads to sufficiently high 97% accuracy on the validation dataset, where possible mislabeled data can not be excluded. Later, the team of authors discusses the application of real-world data recorded at EasyDMARC[37]. At the same time, the evaluation of the model for datasets collected from PhishTank[38] and OpenPhish[39], and Alexa[40] is presented, where such datasets were analysed over the course of six months. Moreover, the application of the Probabilistic Neural Network (PNN)-based algorithm is addressed in URL phishing detection, showing that uncertainties can be used as an extra validation step when detecting phishing URLs.

As stated before, the features used in the ML model are extracted only from the URL. The sample URL image in Fig. 1 represents the structure of a simple URL (real URLs often have a much more complicated arrangement).

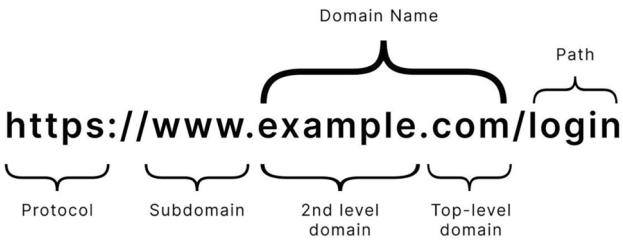


Figure 1. The figure shows a simple URL example breakdown which includes the protocol, subdomain, second-level domain, domain name, top-level domain and path.

An expert with domain knowledge can detect and define features such as the protocol, subdomain, second-level domain, and top-level domain, as well as the domain name and path. Such features are often used in many URL classification works, which is a good idea. However, it is difficult to define all relevant features that impact classification accuracy, even for domain experts. Therefore, our work combined expert-level domain information with ML feature engineering techniques, which are discussed later in the text.

The paper is organised as follows: The section "Related work" discusses a summary of the works reporting the results of classifying websites using different datasets and methods. "Current work" explains the approach taken by the EasyDMARC AI team to construct the datasets for model training and the high-level overview of the model architecture. Whereas some of the information here is IP-related, we present the intuition and general idea behind the method. In "Training, validation and test data", we describe the training, validation and test and explain why we used those datasets. The "Results" section presents the outcome of NN- and PNN-based models given the sample from the validation dataset, as well as OpenPhish, Phishtank and production datasets over six months.

Related work

This chapter mentions several research papers that used different features and ML algorithms to report high (higher than 95%) classification accuracy on datasets prepared by the authors themselves or obtained from elsewhere. A summary of the accomplished works, the year when the work was published, the number of data points of phishing and legitimate URLs, sources of used datasets and reported best results are shown in Table 1. Some of the researchers at hand used third-party services and/or web content, while others used neither. The average classification accuracy for the datasets under discussion is very high, which is encouraging for testing in real-world scenarios.

Purbay et al.[31] used a UCI Machine Learning Repository[43]dataset with different train and test splitting ratios and a number of supervised ML algorithms. They found that using n lexical features, Whois properties, PageRank, Traffic Rank details and page importance properties and Random Forest Classification (RFC) with a train/test split ratio of 0.2 leads to the best accuracy of 96.92%.

Wang et al.[41] proposed a phishing website detection method called PDRCNN, based on features extracted from URLs only and not dependent on third-party services and website content. The research utilises Long-Short Term Memory (LSTM) and Convolutional Neural Network (CNN) to classify URL samples from Alexa[40] and PhishTank[38]. The total dataset comprises 500,000 URLs, and the authors report a classification accuracy of 97%.

Shirazi et al.[32] used only 7 features and achieved a classification accuracy of 97% on sample composed of 1,000 legitimate URLs from Alexa[44], 1000 phishing URLs from PhishTank[38] and 2013 phishing URLs from OpenPhish[39]. The researchers did not use third-party features and discuss the model bias coming from several features, such as the URL length. Shirazi et al. also used Gradient Boosting (GB) to obtain best accuracy on classification.

Guo et al.[42] took advantage of constructing Heterogeneous Information Networks (HIN) from features extracted from link relationships within the website, domains and resource objects. The authors found that phishing websites tend to have foreign links compared to legitimate websites. In total, around 14 features were used. Guo et al. solved the classification problem using phishing and legitimate URLs obtained from OpenPhish[39] and Alexa[44]. They then evaluated the model on phishing and legitimate URLs obtained from Phishpedia[33] and cleaned to 20,556 and 20,949 data points, respectively.

Das et al.[36] used 15 URL-based and 10 hyperlink-based features to construct a hybrid feature set. The authors developed and used their own dataset. The extracted features include the length of the URL, the domain of the URL and the presence of an IP address in the URL. The hyperlink features were extracted from the website's source code and include features such as no hyperlink, internal hyperlink ratio and external hyperlink ratio. Despite the absence of third-party features, Das et al.[36] reported 84.67%, 98.42% and 99.17% classification accuracy using XGBoost (XGB) for hyperlink-based, URL-based and hybrid features respectively.

Aljofey et al.[35] used features based on URLs with a fixed URL maximum length of 200, 13 hyperlinks and textual content of the website and excluded any third-party features in their work. They used Term Frequency-Inverse Document Frequency (TF-IDF) in the data preprocessing pipeline, generating 20,332 features with an XBG report accuracy of 96.76% in their own dataset of 32,972 legitimate and 27,280 phishing websites.

Work	Date	Data	Phish	Legit	Algo	Third-party/Web content dep.	ACC (%)
Purbay[31]	2015	UCI	4,898	4,898	RFC	Yes/NA	96.92
Shirazi[32]	2018	PhishTank, OpenPhish, Alexa	3013	1000	GB	NA/Yes	97
Wang[41]	2019	Alexa, PhishTank	245,385	245,023	LSTM CNN	No/No	97
Guo[42]	2021	OpenPhish, Alexa	NA	NA	HIN	NA/NA	98.56
Das[36]	2022	NA	3000	3000	XGB	NA/Yes	99.17
Aljofey[35]	2022	Own	27,280	32,972	XGB	NA/Yes	96.76

Table 1. The table shows related work and datasets used, if available, with reported classification accuracy.

Unfortunately, none of the above authors reported on the accuracy of their models on real-world production data. The possibility of data drift for longer periods (6 months and more) was also not discussed. In this regard, in the next section, "Current work", we discuss not only the data collection, preprocessing and model architecture, but also model validation using real-world production data and data obtained from live blacklists from PhishTank and OpenPhish from 01.04.2022 to 31.10.2022.

Current work

This section focuses on data collection, historical introduction of the publicly available datasets used in this work, data preprocessing and the model architecture.

Data collection

The Alexa Top 1 Million dataset[40] was used throughout our experiments to obtain domain samples which can be categorised as legitimate. This dataset is composed of the URLs of the top 1 million websites. The domains are ranked based on Alexa traffic ranking characteristics such as the browsing behaviour of users on the website, the number of unique visitors and pageviews. The dataset is reasonably accurate, easily accessible and is a well-known resource.

The OpenPhish Database[39] is a continuously updated archive of structured and searchable information on all phishing websites detected by OpenPhish. In addition, the database contains metadata that can be used for detecting and analysing cyber incidents, searching for patterns and trends or for training and validation in AI applications. OpenPhish receives millions of unfiltered URLs from various sources on its global partner network and reports up-to-date phishing URLs[45].

PhishTank, an offshoot of Open Domain Name System (OpenDNS), is an anti-phishing site[38]. It offers a community-based phishing website verification system, where users can submit a suspected phishing website and other users "vote" on whether it is a phishing website or not. OpenDNS was acquired by Cisco[46]. Later, the PhishTank system was turned over to Cisco Talos[47]. The PhishTank dataset is provided free for download or for access via an Application Programming Interface (API) call, including for commercial use, under a restrictive licence.

EasyDMARC is an all-in-one email security SaaS platform. In addition to email authentication tools, it also offers phishing URL detection based on AI algorithms. EasyDMARC gathers legitimate and phishing URLs on a daily basis through its internal research and data collection module. It receives user-generated data via its phishing URL tool[48].

A summary of the datasets included and used in this work for training, testing and validation is presented in Table 2. Non existing URLs were removed during the data cleaning.

Data exploration and preprocessing

Given the extensive scale of our study, which involved the collection and analysis of huge number of URLs (for example, only Alexa dataset includes a million URLs), a manual inspection of each individual URL was not practically feasible within the constraints of our resources and time. Upon further exploration, it has been found that URLs can be clustered into two categories when it comes to the length of the URLs. For example, one can define short URLs as those with less than 50 characters; thus, long URLs have more than 50 characters. In the case of short URLs, it becomes harder to find phishing patterns as there is not much space for them. The latter statement was further confirmed when experimenting with different ML models. Low accuracy on short URLs and high accuracy on long URLs was reflected based on the testing data. In addition, it was found that some phishing URLs look like well-known legitimate URLs or include domain names in the URL to trick users and make an impression of being legitimate.

To address the issues mentioned above when using raw datasets, one has to apply careful and correct data preprocessing to keep the features specific to phishing and legitimate URLs. Thorough preprocessing can reduce noisy data and increase explainability.

Upon researching different preprocessing pipelines, our results show that the choice of the preprocessing steps is as important as the choice of the final prediction model. When slightly changing the preprocessing pipeline, changes to the model metrics deviate on a large scale, indicating the speculation above. However, before creating automated preprocessing pipelines for model training and inference, it is essential to consider detailed data exploration and manual preprocessing.

Hereafter, the description of general data preprocessing steps is discussed. The URLs are converted to one scheme by keeping the HTTP/HTTPS protocol, removing the 'www' subdomain, and removing the slashes at the end. In this case, the 'www' subdomain is set as a stopword and can be removed. We addressed the other challenges mentioned above by making the URLs canonical and resolving them by sending an HTTP request

Source	Phishing	Legit	Date
PhishTank[38]	85,000	0	2022-02-28
OpenPhish[39]	80,000	0	2022-02-28
Alexa[40]	0	220,000	2022-02-28
Private	55,000	0	2022-11-10

Table 2. Table represents the dataset availability and the number of legitimate and phishing URLs. The private dataset was collected at EasyDMARC AI.

to extract the final URLs. After extracting the final URLs, we proceeded to analyse the lengths and depths of the URL for distribution. The URL length is the number of characters in the URL string, and the URL depth is the number of slashes after the top-level domain. The dataset must exclude imbalances in the URL lengths and URL depths. If it has an imbalance, the prediction model will lack the capability to predict short or long URLs correctly, deep URLs, shallow URLs or only-domain URLs. In such cases, an altering weight on each training data example must be introduced. In the following preprocessing step, tokenization and vectorization were done to separate possible English words and renowned domain names. The URLs are made canonical and resolved, which means the URL is inspected to have the starting address, for example, http or https and corrected to include the redirected URL, if it is present. The tokenization and vectorization can be done using various libraries that tokenize a text. After the data exploration and cleaning, preprocessing pipelines were constructed to convert the URLs into n-dimensional vectors.

while $i < N$ **do**
  URL scheme
  if $subdomain_{(www)}$ = True **then**
    $subdomain_{(www)}$ removal
  end if
  if last slash = True **then**
    last slash removal
  end if
  make canonical
  resolve URL
  balance URL dataset
  tokenization
  vectorization
end while

Algorithm 1. Data Preprocessing Pipeline

Training, validation and test data

The final training and validation datasets contain a random sample from Alexa Top 1 Million dataset, along with the URLs from PhishTank, OpenPhish and Private datasets discussed in Table 2. The train-validation split ratio was selected as 0.2 after applying random shuffle on the preprocessed dataset. The training and validation datasets consist of 85,000 phishing URLs from PhishTank, 80,000 phishing URLs from OpenPhish, 55,000 phishing URLs from private dataset and a random sample of 220,000 legitimate URLs from the Alexa dataset. In total we have 220,000 phishing URLs and 220,000 legitimate URLs, which was split into a train and validation dataset using stratified split random shuffling. Unfortunately, we did not keep the sources of the dataset during the random shuffle and split, therefore we are not able to report the exact number of URLs in train and validation data which originate from each of the above mentioned sources.

The test dataset was created as follows. First, the phishing URLs were obtained from PhishTank and OpenPhish in the period from 01.04.2022 to 31.10.2022. The trained model was used to create a Phishing URL check tool[48] which allows users to submit a URL, check the model prediction result and obtain a report indicating whether the prediction result is correct or not. As a final validation step, URLs collected by EasyDMARC were used to cross-check the model prediction results and data from the production environment using the EasyDMARC production dataset. Test dataset includes 313,000 and 205,000 phishing URLs collected from PhishTank and OpenPhish respectively and data collected using the phishing URL checker tool from EasyDMARC, after the model was deployed to production, and it includes 37,500 phishing and 40,500 legitimate URLs.

ML model architecture

The machine learning model architecture was developed in-house using transfer learning techniques on deep neural networks. Two models have been created where the first model uses a deterministic NN (deterministic model), architecture based on BERT (Bidirectional Encoder Representations from Transformers)[49] and the second one uses the PNN (probabilistic model) including results published by Blundell et al.[49]. In our study, we employed fine-tuning techniques to adapt a NN based on BERT for our specific task, enhancing the model's performance by tailoring its knowledge to the intricacies of our domain. Fine-tuning BERT involves taking a pre-trained BERT model, which has already been trained on a large corpus of text data, and adapting it to a specific task or domain by further training it on a task-specific dataset. During fine-tuning, the parameters of the pre-trained BERT model are updated based on the task-specific data, in our case phishing and legitimate URLs, allowing the model to learn task-specific features and nuances. This process typically involves updating the weights of the model's neural network layers through backpropagation using gradient descent or a similar optimization algorithm. This fine-tuning process allowed us to leverage BERT's pre-trained representations and refine the neural network to achieve superior results in our targeted application.

The model architecture combines two main components: embedding layers and classification layers. After URL tokenization, neural network embeddings are included for vectorisation. The embedding layers include attention layers that are trained along with classification layers. The tokenized URLs include tokens representing the URL's main components, such as HTTP/HTTPS protocols, domains, subdomains, etc., as well as different

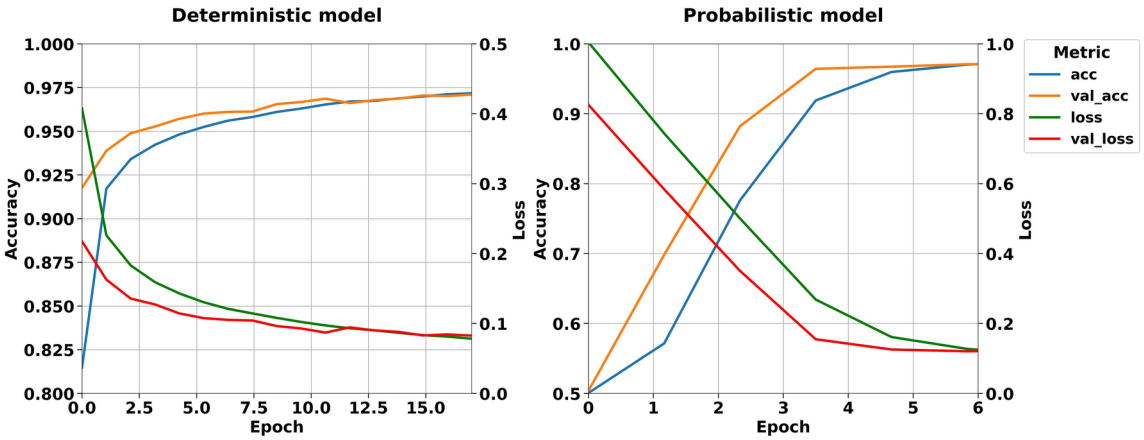


Figure 2. The figure shows the learning curves for both probabilistic and deterministic models. The deterministic model reached a 97% accuracy after 17 epochs of training. The probabilistic model reached 97% accuracy throughout 7 epochs of training.

Dataset	Accuracy (%)
Alexa Top 1 Million	99
Openphish	97.8
Phishtank	94.92
Private	97.71

Table 3. The table represents the accuracy of the deterministic model on datasets: Alexa Top 1 Million, OpenPhish, Phishtank and the private dataset collected at EasyDMARC, where possible mislabeled data can not be excluded.

substrings that can be abbreviations, English words and other contextual components. Hence, the embedding layers are assumed to grasp both the contextual meanings and the technical importance of the tokens. The classification layers are added above the embedding layers to derive the phishing probability of the input URL.

Further experiments were conducted to increase the accuracy and provide a confidence interval for the predicted probability of the ML model. The above-described model lacks the capability to provide uncertainty levels because of its deterministic nature. In the case of the deterministic model, the output is always the same for the same input, and it becomes impossible to provide a certainty measure for one output. We implemented a probabilistic approach to overcome the latter. The deterministic model did find the correct patterns with high accuracy; therefore, a probabilistic model was built on top of the deterministic model, which introduced distributions to weights of the neural network as discussed in the paper Weight Uncertainty in Neural Networks by Blundell et al.[49]. The latter is capable of indicating how uncertain the model is in its prediction.

Results

The probabilistic and deterministic models were trained for 7 and 17 epochs respectively. Learning curves for train and validation datasets are presented in Fig. 2.

First, results from the deterministic model are presented. In this case, the validation dataset was used to report the metrics. Thereafter, the results from the probabilistic model are shown and compared with the deterministic model using a randomly-sampled dataset from the validation data.

Deterministic model

The deterministic model achieves a 97% accuracy on average for the test dataset (see Table 3). State-of-the-art results are observed for each dataset compared to the existing literature shown in Table 1. However, one-to-one comparisons are not possible due to the difference in the number of data points in the datasets addressed in this work and in the related literature mentioned earlier. Owing to the computational demands associated with probabilistic model, especially their extended runtime, we chose to report accuracy based on a subset of the validation dataset. This decision was crucial to uphold practicality and efficiency in managing the intricate nature of probabilistic models, enabling us to provide insightful results while effectively managing computational resources. Additionally, it allowed us to do the evaluation of multiple probabilistic models considering the limited time available for the development of the model. A sample of the validation dataset is used to compare the deterministic and probabilistic models, which is presented in the next two subsections.

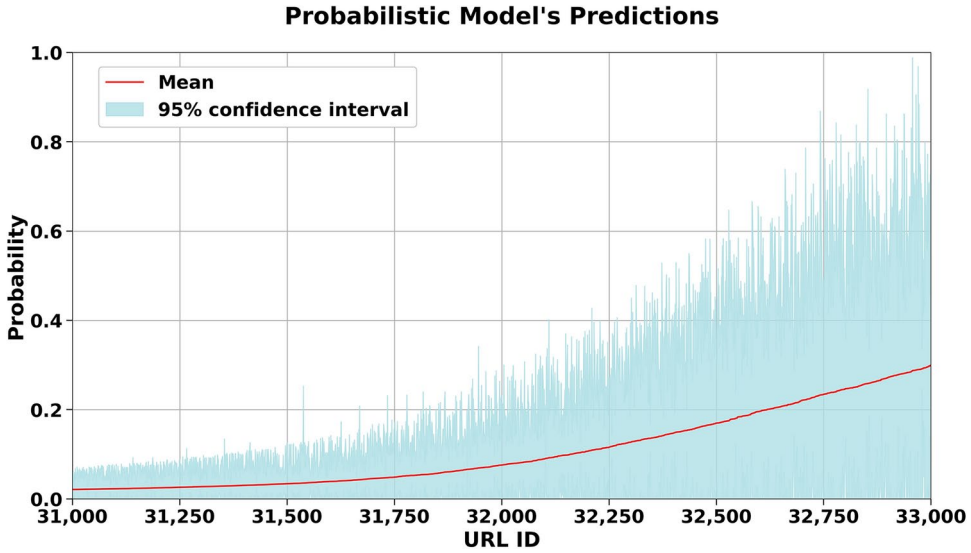


Figure 3. The figure shows the mean and the 95% confidence interval bounds of the prediction probability array outputted by the probabilistic model.

True prediction	False prediction
1.97%	18.13 %

Table 4. The table represents the percentage of URLs in which predictions change when considering the CI range.

Probabilistic model

The probabilistic model makes an inference 100 times for each URL, and the outputted probabilities become our prediction probability array for the inputted URL. The metrics for the probabilistic model were calculated by considering different estimates. These estimates include the mean predicted probability and the 95% confidence interval (CI) bounds. The 95% confidence interval bounds are used to determine the prediction uncertainty (see Fig. 3). It can be observed that some URLs have a wider uncertainty band when compared to other URLs. The overall correlation between higher mean probability values and wider confidence intervals in the presented figure can be attributed to the aleatoric uncertainty of the probabilistic neural network. As the mean probability values approach around 0.17, the model becomes less certain about the predictions, resulting in increased uncertainty, as reflected by the wider confidence intervals. The accuracy calculation for the probabilistic model involves obtaining a prediction probability array for each URL through 100 separate inferences. Each inference generates a unique set of weights for the neurons, capturing the model's uncertainty.

The probabilistic model was trained for 7 epochs which showed an accuracy of 97% with the mean prediction probability as an estimate. We can see that the probabilistic model covers some of the false predictions with different estimates increasing the overall performance of the model. The uncertainty of the probabilistic model for single prediction serves as an extra validation step in the classification task. In case the uncertainty band crosses the border of 0.5, going above or below the 0.5 value, the model prediction can be discussed as unknown. Depending on the business needs and respective use case, one can take the prediction with the upper or lower uncertainty band to define the class of the URL.

Comparison of deterministic and probabilistic models

For the comparison of deterministic and probabilistic models, we sampled and tested 50,000 URLs from the validation dataset. 6000 out of the 50,000 URLs were falsely predicted by the deterministic model and 44,000 URLs were randomly selected. Considering the CIs of the predictions made by the probabilistic model, one can see that CIs for false predictions are wider and cover more space in the range than for true predictions. This means that, by providing the confidence intervals, we further eliminate false predictions by giving a range of phishing probabilities with 95% CI(see Table 4).

The metrics show that the probabilistic model outperforms the deterministic model (see Table 5). The probabilistic model improves the results of the deterministic model by covering false predictions with the CI bounds as estimates. The F1 score for phishing URLs shows better results when using the CI's right bound (CI max) as an estimate, which was obtained from the probabilistic model's outputs. The F1 score for legitimate URLs is better when using the CI's left bound (CI min) as an estimate, further strengthening the validity of the assumption mentioned above. When picking the CI min as an estimate, we give a False prediction for the URLs with a CI min less than 0.5 and a CI max greater than 0.5. On the other hand, we give a True prediction using CI

Metric	Probabilistic Estimate	Probabilistic	Deterministic
Accuracy	Mean	89.66%	87.76%
Accuracy	CI min	88.29%	87.76%
Accuracy	CI max	91.13%	87.76%
Recall for Legit Data	CI min	99.15%	96.34%
Precision for Legit Data	CI min	83.72%	84.71%
F1 Score for Legit Data	CI min	90.79%	90.15%
Recall for Phishing Data	CI max	80.93%	75.81%
Precision for Phishing Data	CI max	97.43%	93.71%
F1 Score for Phishing Data	CI max	88.41%	83.82%

Table 5. The table represents the following classification metrics in case of probabilistic and deterministic models: Accuracy on the validation dataset. Recall, precision and F1 scores were calculated on legitimate and phishing URLs.

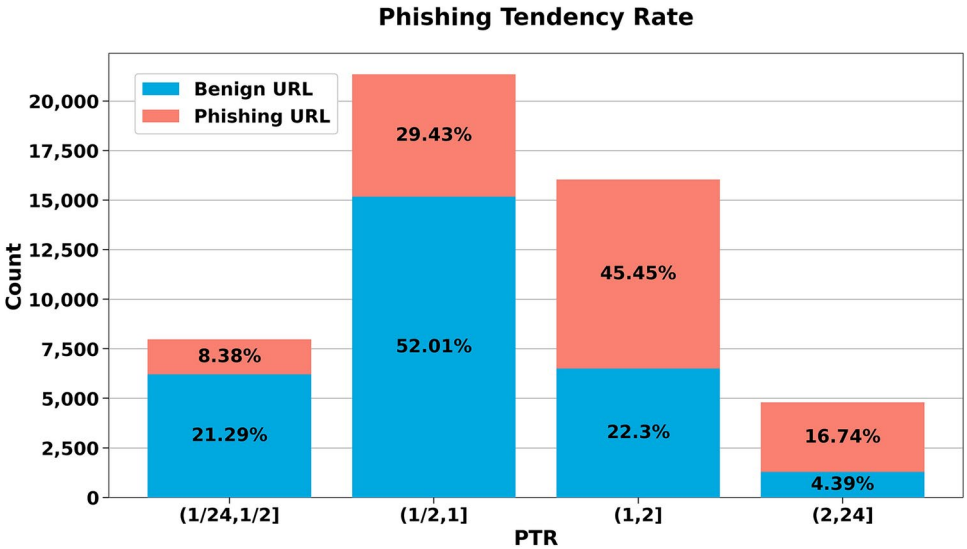


Figure 4. The figure shows the Phishing Tendency Rate distribution for 50,000 URLs sampled from the test data. The percentages in red show the percentage of phishing URLs that have the PTR of the bar in the overall phishing URLs. The percentages in blue show the same percentage for legitimate URLs.

max for the URLs with CI bounds on both sides of 0.5. Table 5 shows that F1 scores improve when using CI min as an estimate for legitimate URLs and CI max for phishing URLs which is done purely for testing purposes. It shows that the approach of giving CI bounds for the prediction improves the prediction quality and successfully provides an explanation for the cases when the model is uncertain.

The other assumption that the probabilistic model is assumed to show is that for phishing URLs, the mean of the prediction probabilities should tend towards 1. For legitimate URLs, it should tend towards 0. As the prediction probability array covers only a segment from the [0,1] interval, and outliers may also be present in the array, we check if the mean tends to the 97.5 percentile of the array or the 2.5 percentile. For this, we define the Phishing Tendency Rate (PTR), which is calculated in the following way:

$$PTR = \frac{|X_{2.5} - \mu|}{|X_{97.5} - \mu|}, \tag{1}$$

where X_i is the ith percentile of the prediction probability array and μ is the mean prediction probability.

PTR greater than 1 means that the mean prediction probability tends to the 97.5 percentile, and PTR less than 1 is for the mean prediction probability that tends to the 2.5 percentile. It is assumed that the μ, 2.5 and 97.5 percentiles estimated from 100 prediction probabilities are close to percentiles that we would obtain with a bigger prediction probability array, which means that by providing a more precise prediction, we would still have a PTR similar to the PTR for 100 predictions. Figure 4 shows that for extreme cases of PTR, we see that the assumption made is valid.

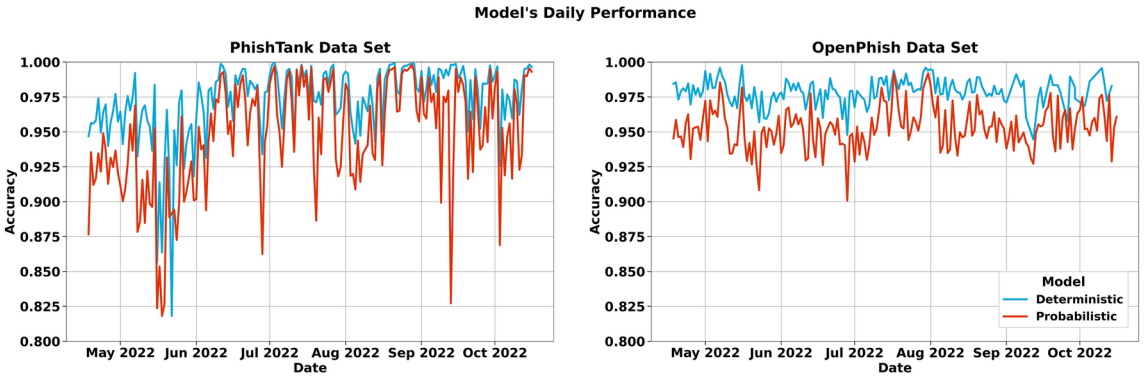


Figure 5. The figure shows the daily accuracy curve of the Deterministic and Probabilistic models on OpenPhish and PhishTank datasets.

URL length	Deterministic	Probabilistic
Short	89%	90%
Long	83.1%	88.3%

Table 6. The table represents the accuracy of both the Deterministic and Probabilistic models on long and short URLs separately.

We can see that for 62% of phishing data points, the PTR is greater than 1. For 71% of legitimate URLs, the PTR is less than 1. For higher values of PTR, we only have 4% of the legitimate URLs. For the other extreme case where PTR is in the range of [1/24,1/2], we only have 8% of the phishing data points.

Further validation was done to ensure consistent high accuracy on OpenPhish and Phishtank datasets. Both the deterministic and probabilistic models were tested daily on those datasets and showed 95% accuracy on average for the probabilistic model and 97% for the deterministic model. (see Fig. 5).

Results on short and long URLs

It should be mentioned that both the deterministic and probabilistic models performed well on short URLs as well, which was a challenge with previous models during the experiments, as already mentioned in the section "Data exploration and preprocessing". Both deterministic and probabilistic models showed high accuracy on short and long URLs separately (see Table 6). The dataset is the randomly sampled data with 50,000 data points, where 6000 URLs were falsely predicted by the deterministic model.

Validation: results on production data

The final model was deployed and has been serving at EasyDMARC[37] since March 2022. During the production phase, we collected the URLs on which the predictions were requested and collected feedback on those predictions. Where predictions do not have any feedback or have feedback as accepted by the users, then those predictions are assumed to be true. If the user did not accept the prediction, then it is assumed that such a prediction is false. The accuracy based on the users' feedback using the deterministic model again shows high results, reflecting an accuracy above 90% on average (see Fig. 6)

Conclusion

In our current work, we have shown for the first time to our knowledge the application of a URL classification model on real production data collected for more than 6 months. Evaluation of our model on different datasets (PhishTank, OpenPhish, Private, where possible mislabeled data can not be excluded) shows high accuracy and F1 scores that are acceptable for real-life applications in production.

Two models utilising neural networks have been applied to solve binary classification tasks to predict phishing and legitimate URLs. A state-of-the-art probabilistic neural network model was trained along with a deterministic neural network-based model to solve the classification task. A comparison of the results of the classification metrics like Accuracy and F1 scores show that it is imperative to use probabilistic neural networks in order to be able to report the confidence of the prediction value. This step is of high importance, since the deterministic model itself, although having high accuracy and F1 scores, is not able to correctly predict the class of a certain margin of URLs. Given the uncertainty from the probabilistic model, we have shown that Precision and F1 scores on the legitimate data can be improved by around 3% and 2.8%, respectively, when comparing probabilistic and deterministic models. At the same time, Precision on phishing URLs was increased by around 5% while having no change on the F1 score. We further show that, in the case of Accuracy, the probabilistic model outperforms the deterministic model by around 4%. The only metric where the probabilistic model could not outperform the deterministic model was the recall of 73.1% with respect to 75.8% from the deterministic

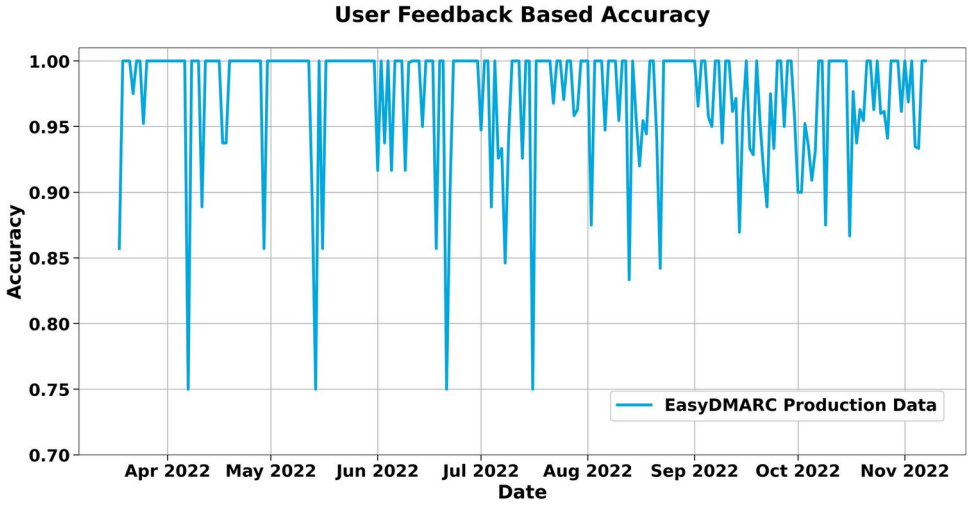


Figure 6. The figure shows the production model's accuracy based on users' feedback. If the result of the phishing detection is accepted by the user, we consider it as a true prediction. If the user disagrees with the result, it is considered a false prediction.

model calculated on phishing URLs only. The deterministic model takes around 2 hours to train, whereas the probabilistic model takes around 1.5 days. When it comes to the inference, the deterministic model can serve the client with an inference time less than a second, whereas the probabilistic model can serve within the 3-5 seconds. It is important to note that those are the values we report when using the NVIDIA GeForce RTX 3060.

Using the private data collected at EasyDMARC, we further evaluated the model in real-life scenarios and confirmed the reported results using the feedback collected from users. Our current work opens new potential applications in URL classification, and brings the possibility to generate reports with confidence intervals from the model which is of high demand among users. This is one of the mandatory steps towards explainable AI which is currently missing in the industry that deals with cybersecurity issues in the domain of phishing URLs, phishing websites and similar.

To summarize, the current work demonstrated the application of a URL classification model on real production data over a 6-month period, marking a novel contribution to the field. It shows that while the deterministic model exhibited commendable accuracy and F1 scores, the probabilistic model outperformed by providing confidence intervals, effectively addressing uncertainties in predicting specific URL classes. We have used the confidence intervals, which addresses the industry demands for explainable AI in the cybersecurity domain, particularly in the context of phishing URLs.

Data availability

The datasets generated during and/or analysed during the current study are available from the corresponding author on reasonable request.

Received: 7 August 2023; Accepted: 27 September 2024
Published online: 24 October 2024

References

1. Phishing activity trends report: 1st quarter 2022 (Anti-Phishing Working Group, 2022). http://docs.apwg.org/reports/apwg_trends_report_q1_2022.pdf. Accessed: 2022-08-17.
2. Phishing activity trends report: 1st quarter 2012 (Anti-Phishing Working Group, 2022). http://docs.apwg.org/reports/apwg_trends_report_q1_2012.pdf. Accessed: 2022-08-17.
3. Phishing Landscape . https://interisle.net/PhishingLandscape2022.pdf. Accessed: 2022-08-28 (2022)
4. Phishing activity trends report, 1st quarter . https://docs.apwg.org/reports/apwg_trends_report_q1_2021.pdf. Accessed: 2022-08-28. (2021)
5. Carroll, F., Adejobi, J. A. & Montasari, R. How good are we at detecting a phishing attack? Investigating the evolving phishing attack email and why it continues to successfully deceive society. *SN Comput. Sci.***3**, 1–10 (2022).
6. X-Force threat intelligence index . https://www.ibm.com/downloads/cas/ADLMYLAZ. Accessed: 2022-08-28. (2022)
7. Franken-phish: TodayZoo built from other phishing kits. https://www.microsoft.com/en-us/security/blog/2021/10/21/franken-phish-todayzoo-built-from-other-phishing-kits/. Accessed: 2022-08-28.
8. State of IoT 2022: Number of connected IoT devices growing 18% to 14.4 billion globally. https://iot-analytics.com/number-connected-iot-devices/. Accessed: 2022-08-28.
9. Abbas, S. G. et al. Identifying and mitigating phishing attack threats in IoT use cases using a threat modelling approach. *Sensors* **21**, 4816 (2021).
10. Nirmal, K., Janet, B. & Kumar, R. Analyzing and eliminating phishing threats in IoT, network and other web applications using iterative intersection. *Peer-to-Peer Netw. Appl.* **14**, 2327 (2021).
11. Sheng, S. *et al.* An empirical analysis of phishing blacklists. In*Proceedings of 6th Conference on Email and AntiSpam (CEAS 2009)* (2009).
12. Chou, N., Ledesma, R., Teraguchi, Y. & Mitchell, J. C. Client-side defense against web-based identity theft (2004).

13. Prakash, P., Kumar, M., Kompella, R. & Gupta, M. PhishNet: Predictive blacklisting to detect phishing attacks 1–5. https://doi.org/10.1109/INFCOM.2010.5462216 (2010).
14. Drury, V., Lux, L. & Meyer, U. Dating phish: An analysis of the life cycles of phishing attacks and campaigns. In *Proceedings of the 17th International Conference on Availability, Reliability and Security*, ARES '22 (Association for Computing Machinery, 2022). https://doi.org/10.1145/3538969.3538997.
15. Rao, R. & Pais, A. *An Enhanced Blacklist Method to Detect Phishing Websites* 323–333 (2017).
16. Chu, W., Zhu, B. B., Xue, F., Guan, X. & Cai, Z. Protect sensitive sites from phishing attacks using features extractable from inaccessible phishing URLs. In *2013 IEEE International Conference on Communications (ICC)* 1990–1994. https://doi.org/10.1109/ICC.2013.6654816 (2013).
17. Opara, C., Chen, Y. & Wei, B. Look before you leap: Detecting phishing web pages by exploiting raw URL and HTML characteristics. https://doi.org/10.48550/ARXIV.2011.04412 (2020).
18. Who is lookup. https://whois.domaintools.com/. Accessed: 2022-08-28.
19. Page, L., Brin, S., Motwani, R. & Winograd, T. *The PageRank Citation Ranking: Bringing Order to the Web. Tech. Rep.* (Stanford InfoLab, 1999).
20. 7 ways to identify a phishing website. https://easydmarc.com/blog/7-ways-to-identify-a-phishing-website/. Accessed: 2022-08-28.
21. Reuvid, J. *The Secure Online Business Handbook: E-commerce, IT Functionality & Business Continuity* (Gale virtual reference library, Kogan Page, 2005).
22. Dua, S. & Du, X. *Data Mining and Machine Learning in Cybersecurity* (CRC Press, 2016).
23. Thomas, T., Vijayaraghavan, A. & Emmanuel, S. *Machine Learning Approaches in Cyber Security Analytics* (Springer Nature Singapore, 2019).
24. Alazab, M. & Tang, M. *Deep Learning Applications for Cyber Security. Advanced Sciences and Technologies for Security Applications* (Springer International Publishing, 2019).
25. Gupta, B. & Sheng, Q. *Machine Learning for Computer and Cyber Security: Principle, Algorithms, and Practices* (Cyber Ecosystem and Security, CRC Press, 2019).
26. Montasari, R. & Jahankhani, H. *Artificial Intelligence in Cyber Security: Impact and Implications: Security Challenges, Technical and Ethical Issues Advanced sciences and Technologies For Security Applications, Forensic Investigative Challenges* (Springer International Publishing AG, 2021).
27. Chen, X., Susilo, W. & Bertino, E. *Cyber Security Meets Machine Learning* (Springer, 2021).
28. Abdul Samad, S. R. et al. Analysis of the performance impact of fine-tuned machine learning model for phishing url detection. *Electronics* **12**, 1642 (2023).
29. Karim, A., Shahroz, M., Mustofa, K., Belhaouari, S. B. & Joga, S. R. K. Phishing detection system through hybrid machine learning based on url. *IEEE Access* **11**, 36805–36822 (2023).
30. Mamun, M. S. I., Rathore, M. A., Lashkari, A. H., Stakhanova, N. & Ghorbani, A. A. Detecting malicious URLs using lexical analysis. In *International Conference on Network and System Security* 467–482 (Springer, 2016).
31. Purbay, M. & Kumar, D. Split behavior of supervised machine learning algorithms for phishing url detection. In *Advances in VLSI, Communication, and Signal Processing* (eds Harvey, D. et al.) 497–505 (Springer Singapore, 2021).
32. Shirazi, H., Bezawada, B. & Ray, I. "Kn0w Thy Doma1n Name" unbiased phishing detection using domain name based features. In *Proceedings of the 23nd ACM on Symposium on Access Control Models and Technologies* 69–75 (2018).
33. Lin, Y. *et al.* Phishpedia: a hybrid deep learning based approach to visually identify phishing webpages. In *30th USENIX Security Symposium (USENIX Security 21)* 3793–3810 (2021).
34. Jain, A. K., Debnath, N. & Jain, A. K. APuML: An efficient approach to detect mobile phishing webpages using machine learning. *Wireless Personal Communications* 1–22 (2022).
35. Aljofey, A. et al. An effective detection approach for phishing websites using URL and HTML features. *Sci. Rep.* **12**, 1–19 (2022).
36. Das Guptta, S., Shahriar, K. T., Alqahtani, H., Alsalman, D. & Sarker, I. H. Modeling hybrid feature-based phishing websites detection using machine learning techniques. *Ann. Data Sci.* 1–26 (2022).
37. EasyDMARC. https://easydmarc.com/. Accessed: 2022-08-28.
38. PhishTank. https://www.phishtank.com/. Cisco Talos Intelligence Group, Accessed: 2022-08-25.
39. OpenPhish. https://openphish.com/. Accessed: 2022-08-28.
40. Alexa dataset. http://s3-us-west-1.amazonaws.com/umbrella-static/top-1m.csv.zip. Accessed: 2022-08-28.
41. Wang, W., Zhang, F., Luo, X. & Zhang, S. PDRCNN: precise phishing detection with recurrent convolutional neural networks. *Security and Communication Networks* **2019** (2019).
42. Guo, B. et al. HinPhish: An effective phishing detection approach based on heterogeneous information networks. *Appl. Sci.* **11**, 9733 (2021).
43. Dua, D. & Graff, C. *UCI Machine Learning Repository* (2017).
44. Ghodke, S. *Alexa Top 1 Million Sites*. https://www.kaggle.com/datasets/cheedcheed/top1m. Accessed: 2022-08-28.
45. Phish Report. https://phish.report/contacts/OpenPhish. Accessed: 2022-08-28.
46. Cisco Acquisitions. https://www.cisco.com/c/en/us/about/corporate-strategy-office/acquisitions.html. Accessed: 2022-08-28.
47. TALOS. https://talosintelligence.com/. Accessed: 2022-08-28.
48. Phishing URL check. https://easydmarc.com/tools/phishing-url. Accessed: 2022-08-28.
49. Blundell, C., Cornebise, J., Kavukcuoglu, K. & Wierstra, D. Weight uncertainty in neural network. In *International Conference on Machine Learning* 1613–1622 (PMLR, 2015).

Author contributions

H.G. and E.I. conceived and conducted the experiment(s), H.G., E.I and A.D. analysed the results. G.H and A.A. collected the private dataset and contributed to research and development. All authors reviewed the manuscript.

Competing interests

The authors declare no competing interests.

Additional information

Correspondence and requests for materials should be addressed to A.D.

Reprints and permissions information is available at www.nature.com/reprints.

Publisher's note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Open Access This article is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International License, which permits any non-commercial use, sharing, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if you modified the licensed material. You do not have permission under this licence to share adapted material derived from this article or parts of it. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit http://creativecommons.org/licenses/by-nc-nd/4.0/.

© The Author(s) 2024